

NARRATIVA EXPLICATIVA

Por qué esta encuesta existe, qué mide y qué puede hacer con ella

Kit de Encuesta FISMA 2025 — Documento de contexto y fundamentación

"Medir es el primer acto de inteligencia. Todo lo que no se mide, o no existe, o existe sin que usted lo sepa."

— Parafraseando a Lord Kelvin, con la licencia que concede la urgencia de la ciberseguridad contemporánea.

Parte I — El Problema: El País de las Métricas Voluntarias

1.1 El Momento en que Estamos

Corría el año 2025 cuando el Centro Criptológico Nacional publicó sus cifras anuales con la discreta alarma que caracteriza a los organismos que saben mucho y dicen lo justo: **278 incidentes críticos gestionados**, un 293% más que el año anterior. Al mismo tiempo, INCIBE registraba **122.223 incidentes** en todo el ecosistema español, un 26% más que en 2024, con 237.028 sistemas vulnerables identificados. España, con toda su vocación mediterránea por el presente, se había convertido en el **quinto país europeo más atacado** en el primer semestre del año.

En ese contexto —y no en el de la calma académica de un laboratorio— nació esta encuesta.

No es una encuesta sobre ciberseguridad en abstracto. Es una encuesta sobre **madurez institucional medible** en las organizaciones que gestionan los servicios esenciales de los ciudadanos: las Comunidades Autónomas, las Administraciones Locales, las infraestructuras críticas y las empresas privadas que les prestan servicios tecnológicos. Es una encuesta que pregunta, con la cortesía de quien sabe que la pregunta incomoda, si realmente sabemos dónde estamos.

1.2 El Problema de las Métricas Ausentes

El sistema de ciberseguridad institucional español tiene una arquitectura normativa razonablemente sólida. El **Esquema Nacional de Seguridad (ENS)**, renovado por el Real Decreto 311/2022, establece un marco de controles bien articulado. El **CCN-CERT** dispone de herramientas de diagnóstico como INES, AMPARO, PILAR y MARGA. La Directiva **NIS2** y su transposición española en marcha establecen obligaciones de gestión de riesgos y notificación de incidentes.

El problema no es la ausencia de norma. El problema es la ausencia de **datos comparables, sistemáticos y territorialmente desagregados** sobre el nivel de cumplimiento e implementación real de esa norma. En España, a diferencia del sistema FISMA norteamericano —donde cada agencia federal reporta anualmente sus métricas a través de CyberScope bajo supervisión de la OMB y auditoría del Inspector General—, no existe un mecanismo equivalente que permita responder con datos a la pregunta: ¿en qué nivel de madurez está la ciberseguridad de la Administración de la Junta de Andalucía, del Gobierno de Canarias o del Ayuntamiento de Valladolid?

Esta encuesta propone cubrir, al menos parcialmente, ese vacío.

Parte II — El Modelo: Qué Mide y Por Qué

2.1 Por qué FISMA como Referencia

El sistema de métricas FISMA FY2025 —concretamente los **FY2025 IG FISMA Reporting Metrics v2.0**— es, a fecha de abril de 2026, el sistema de medición de madurez en ciberseguridad institucional más maduro, sistemático y empíricamente validado del mundo. Sus características lo hacen especialmente valioso como referencia:

- 25 indicadores cuantificables organizados en 10 dominios y 6 funciones del NIST CSF 2.0.
- Modelo de madurez de 5 niveles con definiciones operativas precisas y umbrales de efectividad explícitos.
- Auditorías anuales independientes por Inspectores Generales, con resultados públicos comparables entre agencias.
- Evolución continua: cada ciclo fiscal incorpora las tendencias más relevantes (Zero Trust en FY2025; C-SCRM en Govern; PQC en el horizonte de FY2026-27).

No se propone copiar FISMA. Se propone **aprender de su rigor métrico** y adaptarlo al contexto normativo español: ENS + NIS2 + Anteproyecto de Ley de Coordinación y Gobernanza de la Ciberseguridad.

2.2 La Arquitectura de los 14 Módulos

La encuesta está organizada en **14 módulos** que cubren exhaustivamente los dominios de madurez en ciberseguridad institucional:

Módulos I-II	El gobierno de la seguridad: quién decide, quién responde, quién mide
Módulos III-IV	Los fundamentos técnicos: activos, configuraciones, vulnerabilidades
Módulos V-VI	La identidad y los datos: los dos activos más atacados
Módulo VII	Las personas: el factor humano, el vector favorito de los adversarios
Módulo VIII	La vigilancia: monitorizar es detectar; detectar es sobrevivir
Módulos IX-X	La resiliencia: responder, recuperar y continuar
Módulos XI-XII	El cumplimiento y la métrica: saber dónde estamos para saber adónde vamos
Módulo XIII	El horizonte: las amenazas que ya están aquí (IA) y las que vienen (cuántica)
Módulo XIV	La voz del respondente: el contexto que los datos no capturan

2.3 El Tono: Por qué esta encuesta suena diferente

Las encuestas de cumplimiento normativo tienden a ser áridas por vocación, como si la sequedad del lenguaje fuera garantía de rigor académico. Esta encuesta hace una apuesta diferente: **el rigor y la amenidad no son incompatibles**.

Cada módulo se abre con una cita que enmarca el tema con ironía inteligente. Las opciones de respuesta no se limitan a la escala abstracta sino que **describen realidades reconocibles**: la organización que "gestiona la seguridad de forma reactiva y basada en criterio técnico individual" (Nivel 1) y aquella donde "la ciberseguridad es parte del ADN organizativo, y tenemos datos que lo demuestran" (Nivel 5) no son categorías estadísticas: son organizaciones reales que cualquier CISO reconocerá al instante.

Este diseño tiene un propósito metodológico: **reducir la deseabilidad social** en las respuestas. Una organización que se reconoce en la descripción del Nivel 1 tiene menos probabilidad de marcar la opción A si la opción D describe con precisión su situación real. La ironía benigna y el lenguaje vívido actúan como antídotos de la respuesta aspiracional que contamina los instrumentos de cumplimiento convencionales.

Parte III — La Aplicación: Qué Hacer con los Resultados

3.1 Para la Organización Individual

El resultado primario de la encuesta para cada organización es su **perfil de madurez por dominio**: un mapa que muestra, con precisión de alta resolución, dónde está por encima del umbral de efectividad (Nivel 4+) y dónde está por debajo. Este perfil tiene tres aplicaciones directas:

a) Priorización de inversiones en ciberseguridad:

Los dominios con puntuación más baja y mayor ponderación estratégica (Gobernanza, IDAM, Monitorización) son candidatos naturales para la primera inversión. El perfil de madurez convierte la pregunta presupuestaria de "¿en qué gastamos?" a "¿qué compramos con cada euro para maximizar la reducción de riesgo?".

b) Argumentación ante la dirección:

El IGM y el perfil de madurez proporcionan al CISO el lenguaje que la dirección general entiende: números, posición relativa frente a pares, brechas medibles y ROI estimado de las mejoras. Convierte la ciberseguridad de "problema técnico" en "decisión de gestión".

c) Hoja de ruta hacia la certificación:

Para las organizaciones en proceso de adecuación al ENS, certificación ISO 27001 o preparación NIS2, los resultados de la encuesta mapean directamente los dominios de mejora prioritaria con los requisitos normativos correspondientes (ver documento d del Kit).

3.2 Para el Investigador y el Regulador

El valor agregado de la encuesta —aplicada a una muestra representativa de organizaciones— es la producción de un **mapa de madurez territorial** que no existe actualmente en España:

- Comparativa autonómica: ¿qué comunidades autónomas tienen infraestructuras digitales más resilientes? ¿Qué factores (inversión, tamaño, estructura institucional, modelo de gobierno digital) predicen una mayor madurez?
- Análisis sectorial: ¿el sector sanitario está más maduro que el educativo? ¿Las infraestructuras críticas están por encima del umbral de efectividad FISMA?
- Evolución temporal: aplicada con cadencia bienal, la encuesta produce una serie temporal que permite medir el impacto de las políticas públicas (inversión PRTR, implementación NIS2, despliegue ENS 2.0) sobre la madurez real del ecosistema.
- Calibración normativa: los resultados permiten identificar qué requisitos normativos (ENS, NIS2) tienen menor tasa de implementación real, orientando los esfuerzos de supervisión y apoyo de CCN, INCIBE y la futura Autoridad Nacional de Ciberseguridad.

3.3 Para el Policy-Maker

Los datos agregados de la encuesta pueden fundamentar decisiones de política pública de alto impacto:

- Asignación de fondos: qué CC.AA. y qué tipologías de entidades necesitan más apoyo técnico y financiero (convenios RETECH, PRTR, fondos estructurales europeos).
- Diseño de obligaciones NIS2: qué umbrales de implementación son realistas para las entidades esenciales e importantes en función de su madurez actual.
- Agenda del Centro Nacional de Ciberseguridad: qué dominios requieren programas de apoyo específicos (C-SCRM, Zero Trust, continuidad de negocio) para el conjunto del ecosistema.
- Métricas de seguimiento de la Estrategia Nacional de Ciberseguridad: la encuesta puede operar como instrumento de seguimiento del progreso de la nueva Estrategia Nacional en elaboración.

Parte IV — Las Preguntas que la Encuesta no Hace (pero Implica)

Hay tres preguntas que flotan sobre toda la encuesta, no formuladas pero presentes en cada opción de respuesta:

¿Cuánto nos cuesta no saber dónde estamos?

Un incidente de ransomware en una AAPP autonómica cuesta entre 180.000€ y varios millones de euros directos (recuperación, forense, comunicación, sanciones), más el coste político e institucional de haber fallado en la protección de servicios esenciales a los ciudadanos. Un sistema de métricas que permite detectar y corregir la vulnerabilidad antes del incidente tiene un ROI que raramente se discute en los consejos de gobierno, no porque no sea evidente, sino porque nadie lo ha calculado de forma rigurosa. Esta encuesta empieza ese cálculo.

¿Qué tiene que pasar para que la gobernanza de la ciberseguridad deje de ser un asunto técnico?

La incorporación de la función *Govern* al NIST CSF 2.0 y los indicadores FISMA FY2025 no es un capricho metodológico: es el reconocimiento formal de que la ciberseguridad es, fundamentalmente, un problema de gobierno corporativo e institucional, no de tecnología. La pregunta P2 —sobre la participación del máximo órgano directivo en decisiones de ciberseguridad— es quizás la más importante de toda la encuesta. No porque la respuesta correcta sea difícil de conocer, sino porque el porcentaje de

organizaciones que marcarán la opción E ("la ciberseguridad se considera un asunto que resuelve informática") predecirá, con alta correlación, el perfil de madurez global de esa organización.

¿Estamos midiendo lo que importa?

Esta es la pregunta que los creadores del instrumento se formulan con honestidad. Los 25 indicadores FISMA FY2025, el ENS con sus controles y la Directiva NIS2 con sus 13 áreas temáticas miden lo que es razonablemente medible. Pero la ciberseguridad real incluye dimensiones que ningún cuestionario captura: la calidad del juicio del CISO ante una alerta ambigua a las 3 de la madrugada, la velocidad con que la organización aprende de un incidente, la disposición real de la dirección a priorizar la seguridad cuando compete con otras urgencias presupuestarias. Por eso la encuesta incluye preguntas abiertas, por eso pide una autoevaluación de cultura (P59) y por eso, en última instancia, se lee junto con entrevistas en profundidad y análisis documental, no en su lugar.

Kit de Encuesta FISMA 2025 — Narrativa Explicativa · Versión 1.0 · Abril 2026

Basado en: OMB M-25-04, FY2025 IG FISMA Reporting Metrics v2.0, NIST CSF 2.0, RD 311/2022, ENISA NIS Investments 2025, CCN-CERT Informe de Ciberamenazas 2025